

1.2 Organizational Culture

- Culture shapes how security is understood and practiced
- Influenced by behaviors, norms, structures, values, and geography
- Success requires both **analytical** and **interpersonal** skills
- Security must answer: “**What’s in it for me?**” and “**Why should I care?**”
- Indicators of success

Awareness

Reporting

Integration

Inclusion



In Section 1.2, we shift focus from frameworks and governance structures to something less tangible—but equally powerful: **organizational culture**. No matter how well-designed your security policies or frameworks are, they will struggle—or fail—without the support of a **security-aware, engaged, and accountable culture**.

Let’s start with a basic truth: **every enterprise has a culture**. It may have been purposefully designed or simply evolved over time, but either way, it directly affects how people behave, how decisions are made, and how information security is perceived and executed across the organization.

Culture is shaped by a mix of **organizational behaviors, leadership styles, team dynamics, norms**, and even geographic distribution. It’s also influenced by individual backgrounds—things like education, work ethic, values, and unconscious biases. All of these elements can **either strengthen or undermine** the effectiveness of your security governance.

While information security often relies on **logical, analytical activities**—risk assessments, audits, technical evaluations—**driving real cultural change depends on soft skills**. An effective information security manager needs to know how to **build relationships, influence attitudes, and foster trust**. This requires strong interpersonal and communication skills. It’s not enough to be

technically skilled—you must also be a **leader and educator**.

Creating a security-aware culture means every employee should understand **how information security connects to their role**. From the receptionist to the CEO, each person should be able to answer two key questions:

“What’s in it for me?”

“Why should I care?”

Answering these questions honestly and clearly is the foundation of effective communication. It allows you to **tailor awareness campaigns and training** to each audience, ensuring the message resonates and sticks.

Indicators of a healthy security culture include:

Security being **integrated early** into new projects

End users recognizing and reporting incidents

Staff being able to **identify the security team or manager**

Individuals knowing **their specific role in protecting information assets**

Security must become part of the **organizational DNA**. It should not be an afterthought or the responsibility of just one team. It must be **woven into daily practices**, policies, conversations, and values.

To achieve this, security leaders must actively participate in **committees, cross-functional projects**, and everyday communications. Visibility and approachability are essential. Success comes when **security is seen not as a blocker**, but as a **trusted advisor and partner** in helping the business succeed safely.

1.2.1 Acceptable Use Policy (AUP)

- AUP defines **expected, prohibited, and required behaviors**
- Communicates responsibilities in **plain, accessible language**
- Applies to all users with access to enterprise info assets
- Covers:
 - Access control**
 - Document handling**
 - Mobile use, email & Internet**
- Acknowledgment of policy is critical (HR/compliance collaboration)



Section 1.2.1 of the CISM Review Manual highlights one of the most **tangible and impactful tools** for shaping a secure organizational culture: the **Acceptable Use Policy**, or AUP.

The purpose of an AUP is to clearly define what is **acceptable and unacceptable behavior** when accessing or interacting with the organization's information systems and data. It's a simple concept but a powerful enabler of **risk-aware behavior** across the enterprise.

A well-crafted AUP communicates user responsibilities in **clear, straightforward, and accessible language**. This is not a technical document—it's a **guideline for every employee**, regardless of role or technical background. It outlines what users **must do**, what they **must not do**, and what is **expected** of them in terms of protecting organizational assets.

At a minimum, an AUP typically includes:

Access control requirements (e.g., password use, session timeouts)

Classification and handling of data (how to store, label, and dispose of information)

Disclosure limitations (especially for sensitive or confidential data)

Mobile computing guidelines (e.g., securing laptops, BYOD policies)

Use of corporate email and the Internet

Reporting requirements for suspicious activity or security incidents

Prohibited activities, such as illegal downloads, personal use of company systems, or accessing unauthorized content

The AUP becomes the **baseline for enterprise-wide security behavior**. It helps prevent violations, reduce risk exposure, and support compliance efforts. It also gives the organization a **legal and procedural foundation** for enforcing disciplinary actions if a violation occurs.

However, having the policy isn't enough. One of the most important roles of the **information security manager** is ensuring that the AUP is not only **distributed** but also **understood and acknowledged**. This means it should be part of **onboarding** for every new employee, contractor, or third-party user who will have access to enterprise systems or data.

To ensure this acknowledgment is formalized, the security team should **collaborate closely with HR and the compliance department**. Together, they can ensure that signed acceptance of the policy becomes part of each user's personnel file and that periodic re-acknowledgment occurs as policies evolve. Also, not all users need the same level of detail. The AUP may be supplemented with **role-specific guidance** for users with elevated privileges or special access to sensitive systems. This tailoring ensures relevance and effectiveness.

1.2.2 Ethics in Information Security

- Ethics guide responsible behavior in sensitive security roles
- Aligns with privacy, data protection, and enterprise integrity
- Common concerns: conflicts of interest, data misuse, improper influence
- Tools: ethics training, codes of conduct, ISACA Code of Professional Ethics
- Signed acknowledgment reinforces accountability



Ethics is a foundational concept in information security—**not just in theory, but in daily practice**. In Section 1.2.2, we look at how **ethical behavior** underpins trust, accountability, and legal compliance across all security-related activities. For a CISM professional, **ethics is more than a guideline—it’s a leadership obligation**.

Many enterprises today implement **ethics training programs**, particularly for employees in sensitive roles. These roles might include those who monitor user behavior, conduct penetration tests, or access confidential personal or financial data. In such cases, **misuse or perceived misuse** of access rights can lead to significant reputational and legal consequences for both the individual and the organization.

One of the most important responsibilities for security leaders is to **set the ethical tone**. This means modeling integrity, transparency, and fairness in their own behavior and expecting the same from others. A good framework for professional conduct is the **ISACA Code of Professional Ethics**, which outlines standards for integrity, objectivity, and professionalism for all ISACA members and certification holders.

But ISACA’s code isn’t the only tool. Most enterprises have their own **code of conduct** or **ethics policy**, which should be **formally acknowledged by all**

staff—particularly those with access to sensitive systems. The information security manager should ensure that these policies are **integrated into onboarding** and **reinforced regularly**.

Key ethical risks that information security personnel must be trained to identify include:

Conflicts of interest (e.g., engaging in business with a company they influence)

Self-dealing (using internal information for personal gain)

Accepting inappropriate gifts or bribes

Improper influence over procurement or decision-making

Unauthorized use of corporate assets for personal purposes

Dual employment without disclosure

To mitigate these risks, enterprises should adopt **clear reporting channels**, provide **data ethics frameworks**, and emphasize the connection between **ethical behavior and privacy protection**. For instance, monitoring user activity without transparent policies could lead to ethical and legal breaches—especially in jurisdictions with strong data protection laws.

Ethics also plays a role in broader governance objectives. Aligning ethical practices with **privacy, data protection, and legal compliance** helps create a **consistent, trusted, and resilient enterprise environment**. CISM professionals must be able to **navigate this intersection**, balancing organizational goals with employee rights and public expectations.